ITSX25 Kurs 6

Individuell inlämningsuppgift

Workshop 2 – MITRE ATT&CK och hotanalys

Del 1 – Förstå MITRE ATT&CK som analysramverk

Uppgift 1

MITRE ATT&CK används av säkerhetsteam för att förstå och strukturera hur angripare kan agera mot system och nätverk. Ramverket ger ett gemensamt språk för att beskriva olika typer av angriparbeteenden.

ATT&CK kan användas i en hotanalys genom att koppla observationer och möjliga hot till olika tactics och techniques. Därefter kan säkerhetsteamet undersöka hur dessa beteenden skulle kunna upptäckas och vilka säkerhetskontroller som kan minska risken.

En viktig användning är också att identifiera luckor i försvaret. Om en relevant teknik finns i hotbilden men organisationen saknar bra loggning, detektion eller andra säkerhetskontroller kan detta bli ett förbättringsområde.

ATT&CK hjälper även till med spårbarhet. Vi kan dokumentera vilken teknik vi har identifierat, vilken källa vi har använt och varför vi anser att mappningen är rimlig.

ATT&CK är därför framför allt ett analys- och försvarsverktyg. Det ersätter inte en egen riskanalys, men ger en strukturerad metod för att förstå hot, kommunicera om dem och prioritera säkerhetsåtgärder.

Uppgift 2

ATT&CK ska inte användas som en checklista för att genomföra attacker eftersom ramverket främst används för analys och försvar. Det beskriver olika typer av angriparbeteenden, men syftet i vår hotanalys är att förstå dessa beteenden och fundera på hur de kan upptäckas, förhindras och följas upp.

Det finns en viktig skillnad mellan ett analysramverk och en angreppsinstruktion. Ett analysramverk hjälper oss att förstå varför ett beteende används, vilken risk det innebär och hur vi kan skydda oss.

Om ATT&CK används som en vanlig checklista finns dessutom en risk att analysen blir för mekanisk. Bara för att en teknik finns i ATT&CK betyder det inte automatiskt att den är relevant för vårt projekt. Vi måste ta hänsyn till vår egen miljö, våra tillgångar, vår hotbild och våra säkerhetskontroller.

Vi använder därför ATT&CK för att förstå hotbilden och förbättra försvaret.

Uppgift 3

Initial Access beskriver hur en angripare försöker få sin första åtkomst till en miljö eller ett system.

Execution beskriver hur en angripare försöker få aktivitet eller kod att köras i miljön.

Persistence beskriver hur en angripare försöker behålla sin åtkomst till en miljö över tid.

Discovery beskriver hur en angripare försöker samla information om miljön, exempelvis system, konton och andra resurser.

Impact beskriver aktiviteter som kan påverka system, data eller verksamhetens normala funktion.

Tactics beskriver alltså framför allt angriparens övergripande mål, medan techniques beskriver olika sätt som kan användas för att uppnå dessa mål.

Uppgift 4

ATT&CK kan fungera som ett gemensamt språk mellan red team, blue team och ledningen. Red team kan använda ATT&CK för att beskriva vilka typer av angriparbeteenden som är relevanta. Blue team kan använda samma begrepp för att analysera vilka beteenden som går att upptäcka och vilka försvar som finns.

Det gör kommunikationen tydligare eftersom alla kan använda samma definitioner av tactics och techniques. I stället för att endast säga att något är misstänkt kan teamet beskriva vilket beteende det handlar om och vilken ATT&CK-teknik det kan kopplas till.

ATT&CK kan också förbättra spårbarheten. Vi kan dokumentera vår TTP-mappning, vilken källa som använts och hur säker bedömningen är.

För ledningen kan informationen sedan kopplas till risk och prioritering. Om vi till exempel identifierar ett område där vi saknar bra detektion kan det bli ett nytt backlog-item.

På så sätt kan ATT&CK koppla samman teknisk säkerhetsanalys med projektets fortsatta arbete.

Del 2 – TTP: Tactic, Technique och Procedure

Uppgift 5

Tactic beskriver varför angriparen gör något och vilket övergripande mål som eftersträvas.

Technique beskriver hur angriparen försöker uppnå detta mål.

Procedure beskriver hur en viss teknik används eller har observerats i ett specifikt sammanhang.

Ett exempel är:

Tactic: Discovery
Technique: Account Discovery
Procedure: Aktivitet observeras som tyder på att konton eller användare kartläggs i miljön.

Ur ett defensivt perspektiv kan vi då undersöka om ovanlig kartläggning av konton går att upptäcka genom relevanta loggar och säkerhetskontroller.

Uppgift 6

Teknik 1 – Account Discovery

Tactic: Discovery
Technique: Account Discovery
Procedure: Aktivitet som tyder på att konton eller användare kartläggs i miljön. Ur ett försvarsperspektiv är det relevant att kunna upptäcka när sådan aktivitet avviker från det normala.

Teknik 2 – System Information Discovery

Tactic: Discovery
Technique: System Information Discovery
Procedure: Aktivitet som tyder på insamling av information om system och deras egenskaper. Defensivt kan ovanlig kartläggning av system vara relevant att övervaka.

Teknik 3 – Command and Scripting Interpreter

Tactic: Execution
Technique: Command and Scripting Interpreter

Procedure: Ett kommando- eller skriptbaserat gränssnitt används för aktivitet i miljön. Försvaret behöver kunna skilja mellan normal administrativ aktivitet och aktivitet som avviker från det normala.

Uppgift 7

Jag väljer tacticen **Discovery**.

Tre relevanta techniques inom Discovery är:

- Account Discovery
- System Information Discovery
- Network Service Scanning

De passar eftersom de handlar om att samla information om en miljö. En angripare kan exempelvis försöka förstå vilka användare, system och tjänster som finns.

Ur ett defensivt perspektiv är teknikerna relevanta eftersom ovanlig eller omfattande kartläggning kan vara en signal på att någon försöker förstå miljön.

Uppgift 8

Det kan vara svårt att mappa en observation till rätt technique eftersom samma aktivitet kan ha flera möjliga förklaringar. En aktivitet kan exempelvis vara legitim för en administratör men misstänkt om den utförs av ett ovanligt konto eller vid en ovanlig tidpunkt.

Kontexten är därför viktig. Vi behöver veta vem som utförde aktiviteten, vilket system som berördes, när den skedde och vad som hände före och efter.

Datakvaliteten påverkar också analysen. Om relevanta loggar eller annan information saknas kan det vara svårt att avgöra vilken technique som passar bäst.

Därför behöver vi använda tillförlitliga källor och dokumentera varför vi har gjort en viss mappning. Om vi är osäkra ska vi dokumentera osäkerheten i stället för att presentera en tolkning som ett säkert faktum.

Del 3 – Bygg en defensiv attackkedja

Uppgift 9

En enkel defensiv attackkedja kan beskrivas som:

Initial Access → Execution → Discovery → Credential Access → Impact

Kedjan visar på en övergripande nivå hur ett angrepp kan utvecklas från den första åtkomsten till en möjlig påverkan på verksamheten.

I vår GitHub-board har vi också arbetat med backlog-itemet **Skapa enkel attackkedja**, som är markerat som färdigt. Attackkedjan blir därför en konkret del av vårt säkerhetsarbete i projektet.

Uppgift 10

Steg	Varför?	Hur?	Vad kan vi observera?
Initial Access	Angriparen behöver få en första åtkomst.	Genom ett Initial Access-beteende.	En ovanlig eller misstänkt första åtkomst.
Execution	Angriparen behöver kunna genomföra aktivitet.	Genom en Execution-technique.	Oväntad aktivitet som körs i miljön.
Discovery	Angriparen behöver förstå miljön.	Genom Discovery-beteenden.	Ovanlig kartläggning av konton, system eller nätverk.
Credential Access	Angriparen försöker komma åt autentiseringsrelaterad information.	Genom en Credential Access-technique.	Avvikande aktivitet kopplad till autentiseringsinformation.
Impact	Angriparen försöker påverka verksamheten.	Genom en Impact-relaterad technique.	Förändringar som påverkar system, data eller tillgänglighet.

Tabellen är en förenklad defensiv analys. Mappningen behöver alltid kontrolleras mot den information och de observationer som faktiskt finns. Vi ska alltså inte anta att ett steg har inträffat bara för att det finns med i attackkedjan.

Uppgift 11

Det steg som jag bedömer som mest osäkert är **Credential Access**. Anledningen är att aktiviteter som berör autentiseringsinformation kan ha både legitima och misstänkta förklaringar.

För att förbättra analysen skulle vi behöva veta vilket konto som utförde aktiviteten, vilket system som berördes, när aktiviteten inträffade och om den var förväntad.

Vi behöver även kontrollera vilka loggar som stödjer observationen och om det finns andra händelser som stärker TTP-mappningen.

Om det inte finns tillräckligt med information ska osäkerheten dokumenteras i stället för att vi gör ett säkert påstående.

Uppgift 12

Första kontakt

↓

Initial Access

↓

Execution

↓

Discovery

↓

Credential Access

↓

Impact

↓

Påverkan på verksamheten

Del 4 – Försvarsfrågor och Blue/Purple-perspektiv

Uppgift 13

Initial Access:
Hur kan vi upptäcka ovanliga eller misstänkta första åtkomster?

Execution:
Vilka signaler kan visa att aktivitet körs på ett oväntat sätt?

Discovery:
Kan vi upptäcka ovanlig kartläggning av konton, system eller nätverk?

Credential Access:
Hur kan vi upptäcka misstänkt aktivitet kopplad till autentiseringsinformation?

Impact:
Hur kan vi upptäcka förändringar som påverkar systemens tillgänglighet, data eller normala funktion?

Dessa frågor hjälper blue team att fokusera på vad som behöver kunna upptäckas. I ett purple team-perspektiv kan samma frågor användas för att diskutera om våra säkerhetskontroller faktiskt täcker de beteenden som identifierats i hotanalysen.

Uppgift 14

Account Discovery

Möjliga detektionssignaler är ovanligt omfattande kartläggning av konton, aktivitet från ett konto som normalt inte utför denna typ av aktivitet eller flera Discovery-relaterade händelser under en kort period.

Command and Scripting Interpreter

Möjliga signaler är ovanlig användning av kommando- eller skriptmiljöer, aktivitet från användare som normalt inte använder dessa funktioner eller en kombination av Execution- och Discovery-relaterade händelser.

Signalerna behöver jämföras med normal aktivitet eftersom legitima administratörer också kan utföra liknande aktiviteter.

Uppgift 15

Account Discovery

Möjliga riskreducerande åtgärder är att använda principen om minsta privilegium, begränsa onödiga administrativa rättigheter, logga relevanta aktiviteter och regelbundet se över konton och behörigheter.

Command and Scripting Interpreter

Möjliga åtgärder är att begränsa administrativa rättigheter, använda endpoint-skydd, ha relevant loggning och övervaka avvikande användning. Det är också viktigt att ha tydliga rutiner för administrativ aktivitet.

Åtgärderna bör prioriteras utifrån hur stor risk tekniken innebär för den miljö som analyseras.

Uppgift 16

En attackkedja hjälper säkerhetsteamet att se ett möjligt angrepp som en sammanhängande process i stället för som enskilda händelser. Det gör det lättare att förstå hur olika beteenden kan hänga ihop och var vi kan upptäcka eller stoppa aktiviteten.

Vi kan använda kedjan för att identifiera vilka steg vi har bra synlighet för och vilka steg där vi saknar loggar, detektion eller annan information. Om vi exempelvis har bra synlighet för Initial Access men sämre synlighet för Discovery har vi identifierat ett möjligt förbättringsområde.

Attackkedjan kan också hjälpa oss att prioritera. Vi behöver inte lösa alla säkerhetsproblem samtidigt utan kan fokusera på de områden som innebär störst risk eller där våra kontroller är svagast.

Detta passar även in i vårt projektarbete. På vår GitHub-board är **Skapa enkel attackkedja** färdig, medan säkerhetsrelaterade uppgifter som **Identifiera vilka tekniker och taktiker som är relevanta för oss** fortfarande finns kvar att arbeta vidare med.

På så sätt blir attackkedjan ett underlag för vårt fortsatta backlog- och sprintarbete.

Del 5 – Källor, spårbarhet och kvalitet

Uppgift 17

1. MITRE ATT&CK – Enterprise ATT&CK

https://attack.mitre.org/

MITRE ATT&CK används som huvudkälla för information om tactics, techniques och procedures. Källan hjälper mig att kontrollera att begreppen och TTP-mappningarna används på ett rimligt sätt.

2. MITRE ATT&CK – Enterprise Matrix

https://attack.mitre.org/matrices/enterprise/

Enterprise Matrix används för att se hur tactics och techniques är strukturerade och hur olika tekniker hör ihop med olika delar av ATT&CK.

3. CISA – Best Practices for MITRE ATT&CK Mapping

https://www.cisa.gov/news-events/news/best-practices-mitre-attckr-mapping

CISA:s material används som stöd för hur ATT&CK-mappning bör göras. Det är särskilt relevant för att förstå betydelsen av kontext och varför man behöver vara försiktig med att göra för säkra mappningar när information saknas.

4. MITRE ATT&CK – Data & Tools

https://attack.mitre.org/resources/attack-data-and-tools/

Denna källa används som kompletterande material för ATT&CK-data och verktyg som kan användas vid fortsatt analys.

Uppgift 18

Vi säkerställer att vår TTP-mappning är rimlig genom att jämföra den med MITRE ATT&CK:s officiella beskrivningar.

För varje mappning bör det gå att se vad som ligger bakom bedömningen, vilken tactic och technique som valts och varför den anses passa. Vi behöver även dokumentera vilken källa som stödjer bedömningen.

Om det finns alternativa tolkningar ska dessa tas upp. Om information saknas dokumenterar vi detta som en osäkerhet.

I vårt projekt har vi även en **TTP-Tabell** som är markerad som färdig på GitHub-boarden. Den ger oss ett konkret sätt att strukturera arbetet med TTP och skapa spårbarhet i analysen.

Gruppens arbete används som underlag för projektkopplingen, men resonemangen och formuleringarna i den individuella inlämningsuppgiften är mina egna.

Uppgift 19

Definition of Done för hotanalysen

För att hotanalysen ska kunna betraktas som färdig bör följande vara uppfyllt:

- Relevanta tactics och techniques är identifierade.
- TTP-mappningar har en motivering.
- Källor är dokumenterade.
- Osäkerheter är dokumenterade.
- Attackkedjan är logisk och begriplig.

- Försvarsfrågor finns för relevanta steg.
- Analysen har granskats.
- Relevanta backlog-items har följts upp.
- Kopplingen till Sprint Goal har kontrollerats.
- Dokumentationen finns i GitHub.
- Gruppen kan förklara analysen med egna ord.

På vår GitHub-board finns också **Utöka Definition of Done** som ett pågående arbete. Det visar att Definition of Done inte bara används som en färdig checklista utan också utvecklas när vi identifierar nya behov i projektet.

Uppgift 20

En hotanalys blir användbar för andra när den är tydlig, spårbar och möjlig att följa upp. En person som inte varit med under analysen ska kunna förstå vad som har undersökts, vilka slutsatser som dragits och varför.

Det är därför viktigt att använda ett gemensamt språk, exempelvis MITRE ATT&CK:s tactics och techniques. Varje mappning bör också ha en motivering och en källa så att någon annan kan kontrollera resonemanget.

Det är även viktigt att skilja mellan fakta och antaganden. Om vi saknar information ska detta dokumenteras som en osäkerhet.

Analysen ska dessutom kunna leda till konkret arbete. Om vi identifierar ett säkerhetsområde som behöver förbättras kan det läggas till eller prioriteras i backloggen.

Detta syns även i vår GitHub-board där säkerhetsrelaterade aktiviteter som attackkedja, TTP-tabell och identifiering av relevanta tactics och techniques hanteras som konkreta arbetsuppgifter.

Del 6 – Koppling till backlog, Sprint Goal och Workshop 3

Uppgift 21

Efter Workshop 2 kan hotanalysen kopplas till flera konkreta backlog-items på vår GitHub-board.

Skapa enkel attackkedja – Done
Vi har färdigställt en enkel attackkedja som hjälper oss att strukturera hur ett möjligt angrepp kan utvecklas och var försvarsåtgärder kan behövas.

TTP-Tabell – Done
Vi har färdigställt en TTP-tabell som hjälper oss att strukturera tactics, techniques och procedures och skapa spårbarhet i hotanalysen.

Identifiera vilka tekniker och taktiker som är relevanta för oss – Todo
Detta arbete återstår och är prioriterat som High. Det innebär att vi behöver fortsätta bedöma vilka delar av MITRE ATT&CK som är mest relevanta för vårt projekt.

Utöka Definition of Done – In progress
Detta arbete är prioriterat som Urgent och pågår. Syftet är att utveckla våra kriterier för när ett arbete ska betraktas som färdigt.

Det finns även andra säkerhetsrelaterade backlog-items, exempelvis **Kartlägg de största hoten** och **Skapa en rutin för att upptäcka och rapportera misstänkt phishing**. Dessa visar hur hotanalysen kan kopplas vidare till konkreta säkerhetsaktiviteter i projektet.

På så sätt finns en tydlig koppling mellan Workshop 2, vår hotanalys och den faktiska backloggen i GitHub.

Uppgift 22

Attackkedjan är relevant för vårt Sprint Goal eftersom den hjälper oss att strukturera säkerhetsarbetet och förstå vilka hot och beteenden som behöver prioriteras.

Vår GitHub-board visar att vi redan har färdigställt **Skapa enkel attackkedja** och **TTP-Tabell**. Samtidigt återstår bland annat **Identifiera vilka tekniker och taktiker som är relevanta för oss**, medan **Utöka Definition of Done** fortfarande pågår.

Det visar att delar av hotanalysen är färdiga medan andra delar behöver fortsätta utvecklas. Resultatet från Workshop 2 kan därför användas för att kontrollera att vårt fortsatta arbete fortfarande stödjer Sprint Goal och för att avgöra vilka säkerhetsrelaterade backlog-items som bör prioriteras.

Om ny information visar att en säkerhetsrisk är viktigare än något vi tidigare prioriterat behöver vi kunna ändra prioriteringen i backloggen.

Uppgift 23

Inför Workshop 3 tar vi med oss följande frågor:

- Är våra ATT&CK-mappningar rimliga utifrån den TTP-tabell och attackkedja vi har skapat?
- Vilka tactics och techniques är viktigast för vårt projekt?
- Vilka delar av attackkedjan behöver mer information eller bättre detektionsmöjligheter?
- Hur ska vi utöka vår Definition of Done så att säkerhetsarbetet blir tydligt och spårbart?

Frågorna bygger på både det arbete som redan är färdigt och de aktiviteter som fortfarande finns kvar eller pågår i vår GitHub-board.

Uppgift 24

Inför Workshop 3 tar vi med oss resultatet från Workshop 2 och vårt arbete i GitHub.

Vi har skapat en enkel attackkedja och en TTP-tabell. Dessa arbetsuppgifter är markerade som färdiga på vår board.

Vi har använt MITRE ATT&CK för att strukturera hotanalysen och förstå relationen mellan tactics, techniques och procedures.

Samtidigt finns fortsatt arbete. Vi behöver bland annat fortsätta med att identifiera vilka tactics och techniques som är mest relevanta för oss. Vi arbetar även med att utöka vår Definition of Done.

Inför Workshop 3 vill vi därför kontrollera våra ATT&CK-mappningar, minska de osäkerheter som finns och prioritera vilka säkerhetsområden vi ska arbeta vidare med.

Projektspårbarhet

Projektets GitHub-board används för att skapa spårbarhet mellan hotanalysen och det fortsatta arbetet.

Färdigt:
Skapa enkel attackkedja och TTP-Tabell.

Pågående:
Utöka Definition of Done.

Kvar i Todo:
Bland annat Identifiera vilka tekniker och taktiker som är relevanta för oss, Kartlägg de största hoten och Skapa en rutin för att upptäcka och rapportera misstänkt phishing.

Det gör att vi kan se vad som är klart, vad som fortfarande pågår och vad som behöver prioriteras framöver.

Teamförberedelse

Inför nästa workshop behöver gruppen kunna förklara attackkedjan och TTP-mappningen med egna ord. Vi behöver också veta vilka delar som är färdiga och vilka delar som fortfarande behöver utvecklas.

De öppna frågorna från hotanalysen kan användas under Workshop 3 för att kontrollera våra bedömningar och bestämma nästa steg.

Inför retrospektiv

Vad gick bra?

Vi fick en bättre förståelse för MITRE ATT&CK och kunde koppla TTP till hotanalys och försvar. Vi fick också fram konkreta resultat i form av en enkel attackkedja och en TTP-tabell.

Vad blev svårt?

Det var framför allt svårt att avgöra exakt vilken technique vissa observationer eller beteenden skulle kopplas till. Det kan finnas flera möjliga tolkningar och därför behöver vi ta hänsyn till kontext.

Vad behöver vi ändra?

Vi behöver dokumentera osäkerheter tydligt och kontrollera våra mappningar mot tillförlitliga källor. Vi behöver också fortsätta arbetet med att identifiera vilka tactics och techniques som är mest relevanta för vårt projekt.

Vad tar vi med oss till nästa sprint?

Vi tar med oss en tydligare process för TTP-mappning, källkontroll, dokumentation och prioritering. Vi tar också med oss arbetet med att utöka vår Definition of Done så att det blir tydligare vad som krävs för att säkerhetsrelaterade uppgifter ska betraktas som färdiga.

Källförteckning

MITRE ATT&CK
https://attack.mitre.org/

MITRE ATT&CK – Enterprise Matrix
https://attack.mitre.org/matrices/enterprise/

CISA – Best Practices for MITRE ATT&CK Mapping
https://www.cisa.gov/news-events/news/best-practices-mitre-attckr-mapping

MITRE ATT&CK – Data & Tools
https://attack.mitre.org/resources/attack-data-and-tools/

AI-användning

Jag använde ChatGPT som stöd för att strukturera och formulera delar av hotanalysen samt för att få hjälp med MITRE ATT&CK-begrepp. Jag använde också verktyget för att kontrollera språk, struktur och att samtliga delar av uppgiften hade besvarats.

Jag kontrollerade informationen mot MITRE ATT&CK:s dokumentation och CISA:s material. Jag jämförde även projektkopplingen med vår GitHub-board för att kontrollera att information om backlog och arbetsstatus stämde med gruppens projekt.

Jag har själv gått igenom innehållet, bedömt vilka delar som är relevanta för uppgiften och anpassat texten efter arbetet i projektet. AI användes därför som stöd i arbetet och inte som ensam källa.